

『サイバークライシス』解説ブロック(Q&A;版)

改訂版5準拠／司会(社員役)の質問に、講師・穴吹衛が答える形式

○木川精機・会議室(後日)。本編VTRを見た社員と、講師・穴吹衛。司会は津山が務める。

Q うちみたいな素人に、そこまで責任を負えと言われても困ります。

穴吹「まず安心してください。中小企業に“専門家レベル”は求められていません。求められるのは、誰でもできる「基本」。それを尽くしていたか、が大事なんです」

津山「基本、というと？」

穴吹「パスワードの使い回しをやめる、ログインに多要素認証、こまめな更新、バックアップ。IPA——国の機関が、中小企業向けに無料で手引きを出しています(SEcurity ACTION など)」

Q 正直なところ、損害賠償なんて、本当に起きるんですか？

穴吹「“自動的に発生する”ものではありません。賠償は、契約違反や過失——つまり注意義務を怠ったか、因果関係はあるか、といった点が争点になります。中小だから必ず、というものではない」

津山「じゃあ、心配すぎ？」

穴吹「いいえ。“広く知られた基本”を、警告がありながら怠っていた場合は、責任を問われるリスクが現実になります。実際、委託先が侵入口になった事例で、責任が問題になったケースもあります。判断はケースごと——不安なら、弁護士や専門機関にご相談を」

Q 難しいことは無理です。何から始めれば？

穴吹「3つだけ。①多要素認証を「オン」に ②自動更新を「オン」に ③バックアップを1つ、ネットから切り離して持つ。これだけで、入られにくく・戻せるようになります」

津山「自分たちでできないときは？」

穴吹「ITベンダーやMSSPに任せる、IPAやお近くの相談窓口聞く。“分からないから相談する”は、立派な対策です」

Q お金がないんです。コストが心配で。

穴吹「基本の多くは、月に数万円——無料の手引きや相談先もあります。一方、起きてしまうと、復旧費に、取引先対応に、場合によっては賠償まで。桁が変わります」

穴吹「対策費は、いちばん安い保険だと思ってください。心配なら、サイバー保険という選択肢もあります」

Q もし、起きてしまったら？

穴吹「隠さないこと。すぐに相談・報告です。IPA、JPCERTコーディネーションセンター、警察(#9110)。そして、身代金は払わない——払っても戻る保証はなく、次を呼びます」

穴吹「証拠(ログ)を消さずに残し、取引先には“分かること・分からないこと”を分けて正直に。その姿勢が、信頼を守ります」

Q そもそも、うちが原因だなんて、どうやって分かるんですか？

穴吹「正直、自社“だけ”では気づきにくいんです。最初に分かるのは、せいぜい「自社のVPNに不審なログインがある」というところまで」

津山「取引先に入られた、というのは？」

穴吹「それは、取引先側の調査で「侵入の起点が御社経由らしい」と分かり、連絡が来て初めて見えてきます。その後、両社のフォレンジック調査やJPCERTの連携で、経路が裏付けられる」

穴吹「だからこそ、普段からログを残し、おかしい兆候に気づける備えと、すぐ相談できる先を持つておくことが大事なんです」

Q うちが原因で、電車や銀行や電気が止まったりは？

穴吹「そこは誤解されがちですが――電力・鉄道・金融などの重要インフラは、多重化やフェイルセーフで設計されていて、一社の事故で社会のサービスが止まることは、まず起きにくい」

穴吹「現実に深刻なのは、“自社が止まること”と“取引先に損害を与えること”。等身大のここに、力を入れましょう」

○締め

穴吹「“専門家になってください”ではありません。“基本”を、今日から。難しければ、相談していい先がある。それで、足元の穴はふさげます」

多田「(カメラ目線)――あなたの会社の“穴”、塞ぎませんか」

※司会・質問は社員役(津山)。賠償・実例の表現は法務監修で確定。窓口/ガイドライン名は最新確認。社名・金額は架空。